

Documentação Técnica

Ferramenta Automatizada de Diagnóstico de Segurança Web (SSL/TLS)

Auditoria de segurança com agentes de Inteligência Artificial - Cenário 1: Servidor Web

Autor: Gabriel Gomes Galikosky; Paulo José de Oliveira Rolinski; Ricardo André da Silva
Plataforma: n8n • IA: Claude (Anthropic) • Análise: Qualys SSL Labs

Sumário

Sumário	2
1. Objetivo	4
Objetivos específicos	4
2. Visão Geral da Solução	4
3. Arquitetura	4
3.1 Componentes do fluxo	5
4. Fluxo de Execução	6
5. Tecnologias Utilizadas	7
6. Dados Coletados e Analisados	7
7. Vulnerabilidades Verificadas	7
8. Saídas e Relatório	8
9. Tratamento de Erros e Resiliência	8
10. Segurança e Privacidade	8
11. Pré-requisitos e Configuração	9
12. Como Usar	9
13. Limitações e Trabalhos Futuros	9

1. Objetivo

Esta ferramenta tem como objetivo automatizar a auditoria de segurança de servidores web, com foco na camada de transporte seguro (SSL/TLS), utilizando agentes de Inteligência Artificial para interpretar os resultados técnicos e produzir um relatório claro e acionável. A partir de um formulário simples, em que o usuário informa um domínio e um e-mail, toda a análise é executada em segundo plano e o resultado é entregue por e-mail.

O relatório final contém as três saídas exigidas pelo projeto: a lista de vulnerabilidades e configurações inseguras identificadas, a classificação de risco e as recomendações de correção.

Objetivos específicos

- Analisar os protocolos SSL/TLS suportados e identificar versões obsoletas e inseguras.
- Avaliar o certificado digital: validade, emissor, algoritmo e tamanho de chave.
- Detectar vulnerabilidades conhecidas e falhas de configuração do servidor.
- Classificar o nível de risco geral da configuração analisada.
- Gerar recomendações de correção priorizadas e acionáveis.
- Entregar o resultado de forma automatizada e legível, por e-mail.

2. Visão Geral da Solução

O escopo deste projeto corresponde ao Cenário 1 - Servidor Web, dedicado à análise de SSL/TLS, certificados digitais e configurações de segurança da conexão. A solução é composta por dois elementos principais: uma interface web (formulário) e um fluxo de automação orquestrado no n8n, que integra a análise técnica, a inteligência artificial e o envio do relatório.

Do ponto de vista do usuário, o uso é direto: ele acessa a página, informa o domínio e o e-mail e inicia o diagnóstico; recebe imediatamente a confirmação de que a análise começou; e, em poucos minutos, recebe o relatório completo por e-mail.

3. Arquitetura

A solução adota uma arquitetura orientada a eventos (event-driven), com um único fluxo no n8n exposto por dois webhooks na mesma origem, o que evita problemas de CORS. A rota de apresentação (GET /diagnóstico) serve a página HTML do formulário, enquanto a rota de execução (POST /diagnóstico-run) recebe os dados e dispara a auditoria.

A execução é assíncrona: assim que a requisição é recebida, o fluxo responde imediatamente ao navegador (confirmação) e continua o processamento em segundo plano. Como a análise do Qualys SSL Labs também é assíncrona, o fluxo implementa um laço de verificação (polling) que consulta o status periodicamente até a conclusão. Com os dados coletados, um agente de IA (Claude, da Anthropic) interpreta o resultado e redige o relatório em HTML, que é então enviado por e-mail via Gmail.

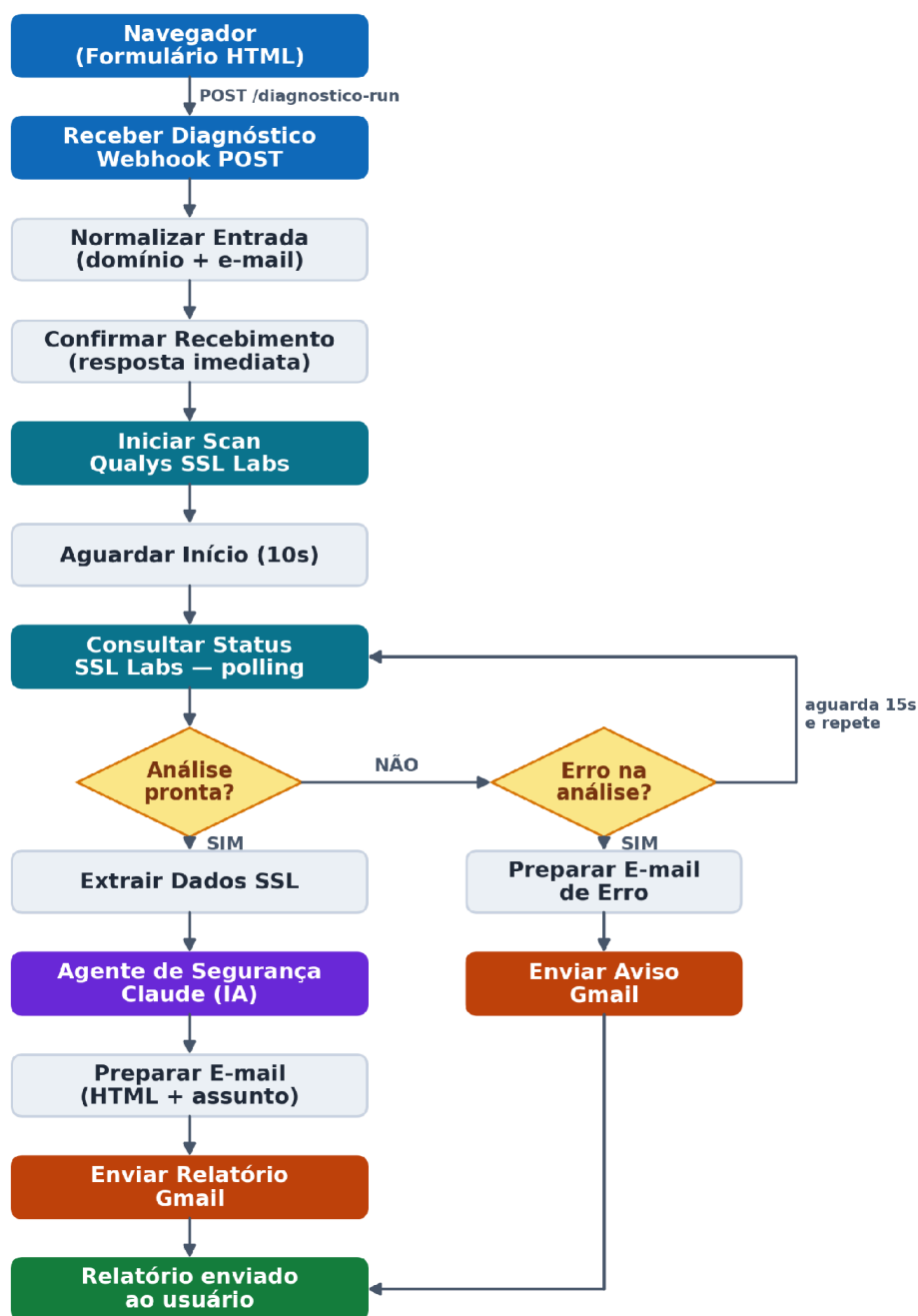


Figura 1 - Fluxo de execução da solução no n8n.

3.1 Componentes do fluxo

Nó (n8n)	Função
Página - Formulário (Webhook GET)	Recebe o acesso à página e dispara a entrega do formulário.

Nó (n8n)	Função
Servir Página HTML / Responder HTML	Monta e devolve a página HTML do formulário ao navegador.
Receber Diagnóstico (Webhook POST)	Recebe o domínio e o e-mail enviados pelo formulário.
Normalizar Entrada	Limpa o domínio (remove protocolo e caminho) e valida o e-mail.
Confirmar Recebimento	Responde imediatamente ao navegador confirmando o início.
Iniciar Scan SSL Labs	Inicia uma nova avaliação na API do Qualys SSL Labs.
Aguardar Início / Aguardar e Repetir	Pausas do laço de verificação (10 s inicial e 15 s entre tentativas).
Consultar Status	Consulta o andamento da avaliação (polling).
Análise Pronta? / Erro na Análise?	Decisões que direcionam o fluxo conforme o status retornado.
Extrair Dados SSL	Extrai protocolos, vulnerabilidades e dados do certificado.
Agente de Segurança (Claude)	Interpreta os dados e gera o relatório, o risco e as recomendações.
Preparar E-mail	Finaliza o HTML do relatório e monta o assunto.
Enviar Relatório / Enviar Aviso de Erro	Envia o relatório (ou o aviso de falha) por Gmail.

4. Fluxo de Execução

A sequência abaixo descreve o ciclo de vida de uma solicitação, do envio do formulário até a entrega do relatório:

1. **Recebimento** - o webhook POST recebe o domínio e o e-mail informados no formulário.
2. **Normalização** - o domínio é padronizado (minúsculas, sem protocolo nem caminho) e o e-mail é validado.
3. **Confirmação imediata** - o fluxo responde ao navegador confirmando o início e segue processando em segundo plano.
4. **Início do scan** - é feita a primeira chamada à API do SSL Labs (parâmetro startNew), iniciando uma nova avaliação.
5. **Espera inicial** - o fluxo aguarda alguns segundos para a avaliação começar.
6. **Verificação de status** - consulta o status atual da avaliação (polling).
7. **Decisão** - se o status é READY, segue para extração; se é ERROR, envia o e-mail de erro; caso contrário, aguarda 15 s e repete a verificação.
8. **Extração de dados** - protocolos, vulnerabilidades e dados do certificado são extraídos da resposta.

9. **Análise por IA** - o agente Claude recebe os dados e gera o relatório em HTML, com classificação de risco e recomendações.
10. **Preparação do e-mail** - o conteúdo é finalizado e o assunto é montado.
11. **Envio** - o relatório é enviado ao e-mail informado, via Gmail.

5. Tecnologias Utilizadas

Tecnologia	Função no projeto
n8n (n8n Cloud)	Orquestração do fluxo de automação (low-code): webhooks, lógica condicional, laços e integração entre os serviços.
Webhooks HTTP	Entradas do sistema: servir o formulário (GET) e receber a solicitação de análise (POST).
HTML, CSS e JavaScript	Interface do formulário (design Microsoft Fluent 2, tema claro), validação de entrada e envio assíncrono (fetch).
Qualys SSL Labs API (v3)	Análise técnica de SSL/TLS, certificados e detecção de vulnerabilidades. API pública e assíncrona.
Claude (Anthropic) - Sonnet 4.6	Agente de IA que interpreta os dados técnicos e redige o relatório, a classificação de risco e as recomendações.
n8n AI Agent (LangChain)	Nó que orquestra a chamada ao modelo de linguagem e o seu prompt.
Gmail (OAuth 2.0)	Envio do relatório e dos avisos por e-mail.

6. Dados Coletados e Analisados

A partir da avaliação do Qualys SSL Labs, o fluxo extrai e analisa os seguintes elementos:

- Nota geral atribuída pelo SSL Labs (de A+ a F).
- Endereço IP avaliado e mensagem de status da avaliação.
- Protocolos suportados e identificação de protocolos obsoletos (SSLv3, TLS 1.0 e TLS 1.1).
- Suporte a TLS 1.3.
- Forward Secrecy (sigilo futuro).
- Suporte a cifras RC4.
- Certificado digital: titular (Common Name), emissor, datas de validade, dias restantes até a expiração, algoritmo e tamanho da chave e algoritmo de assinatura.

7. Vulnerabilidades Verificadas

A análise contempla a verificação das principais vulnerabilidades e fraquezas conhecidas de SSL/TLS:

- Heartbleed.
- POODLE (em SSL e em TLS).

- FREAK, Logjam e DROWN.
- BEAST.
- Uso de cifras inseguras (RC4).
- OpenSSL CCS Injection, Ticketbleed e Bleichenbacher.
- Presença de protocolos obsoletos e ausência de forward secrecy.

8. Saídas e Relatório

O relatório é gerado em HTML, com identidade visual corporativa (cabeçalho na cor de marca, tipografia limpa e selos de severidade discretos), e enviado por e-mail. Sua estrutura é a seguinte:

- **Cabeçalho e painel de nota** - domínio, nota do SSL Labs, IP e data da análise.
- **Resumo executivo** - visão geral da postura de segurança.
- **Vulnerabilidades e configurações inseguras** - cada item com severidade (Crítico, Alto, Médio ou Baixo) e explicação do risco.
- **Certificado digital** - apresentado em formato de tabela.
- **Classificação de risco geral** - nível único com justificativa.
- **Recomendações de correção** - lista priorizada e acionável.

Dessa forma, as três saídas exigidas - lista de vulnerabilidades, classificação de risco e recomendações de correção - estão integralmente contempladas no relatório entregue ao usuário.

9. Tratamento de Erros e Resiliência

- **Laço de verificação (polling):** como a avaliação do SSL Labs é assíncrona e leva de 1 a 3 minutos, o fluxo consulta o status repetidamente (a cada 15 segundos) até a conclusão.
- **Tolerância a falhas de rede:** as chamadas HTTP são configuradas para não interromper o fluxo diante de respostas transitórias.
- **E-mail de erro:** quando a avaliação retorna ERROR, o usuário recebe um e-mail informando que não foi possível concluir a análise.
- **Falhas transitórias do scanner:** o SSL Labs pode, ocasionalmente, não completar a avaliação de um servidor; nesses casos, a reexecução do diagnóstico costuma resolver.

10. Segurança e Privacidade

- **Credenciais protegidas:** a chave da API da Anthropic e o acesso ao Gmail (OAuth 2.0) ficam armazenados de forma segura no n8n, fora do código.
- **Mesma origem:** como o formulário é servido pelo próprio n8n, as requisições ocorrem na mesma origem, dispensando configurações de CORS.
- **Sem persistência de dados:** o fluxo não armazena os domínios analisados nem os e-mails; os dados existem apenas durante a execução.

- **API pré-paga:** o uso do modelo de IA depende de saldo de créditos na conta da Anthropic.

11. Pré-requisitos e Configuração

1. Instância do n8n (n8n Cloud) com o fluxo importado.
2. Credencial da API da Anthropic, com saldo de créditos, conectada ao nó do modelo Claude.
3. Conta Gmail conectada via OAuth 2.0 nos nós de envio.
4. Fluxo publicado/ativo, para que a URL de produção do formulário fique disponível.

12. Como Usar

1. Acessar a URL de produção do formulário (rota GET /diagnóstico).
2. Informar o domínio a analisar e o e-mail para receber o relatório.
3. Clicar em “Iniciar diagnóstico”; a confirmação aparece na tela.
4. Aguardar o e-mail com o relatório (geralmente de 1 a 3 minutos).

13. Limitações e Trabalhos Futuros

- A análise depende da disponibilidade e dos limites de uso da API pública do SSL Labs.
- Avaliações podem falhar de forma transitória, exigindo reexecução.
- O escopo atual cobre o Cenário 1 (servidor web / SSL-TLS); cenários adicionais podem ser incorporados.
- **Evoluções possíveis:** histórico e persistência de relatórios, painel de acompanhamento, agendamento periódico, verificação de HSTS e de cabeçalhos de segurança e suporte a múltiplos destinatários.

14. Prompts utilizados

Formate a documentação técnica completa para o projeto de ferramenta automatizada de diagnóstico de segurança web (SSL/TLS) desenvolvido com n8n.

A documentação deve conter:

- Capa com título, autor, plataformas e versão
- Sumário automático com hyperlinks
- Numeração de páginas no rodapé
- Diagrama do fluxo de execução (fluxograma com todos os nós, decisões e o laço de polling) embutido como imagem
- Seções: Objetivo, Visão Geral, Arquitetura, Fluxo de Execução, Tecnologias Utilizadas, Dados Coletados, Vulnerabilidades Verificadas, Saídas e Relatório, Tratamento de Erros, Segurança e Privacidade, Pré-requisitos e Configuração, Como Usar, Limitações e Trabalhos Futuros

Use formatação corporativa: fonte Arial, títulos com linha azul (#0f6cbd), tabelas com cabeçalho azul.